CRISC Domain B – Impossible Questions

IT Risk Assessment – Expert Level Only (Merged Edition)

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

Every easy and purely definitional question has been removed.
What remains needs calculation, probability, dependency analysis and judgment.
Do not be discouraged if you miss most of them.

Outline

1. Quantitative Risk Analysis
2. Risk Evaluation
3. Business Impact Analysis
4. Risk Treatment
5. Risk Monitoring
6. Answer Key and Summary

Q1: Control ROI

Question

An asset is worth $2M with an exposure factor of 40% and an ARO of 0.5. A control reduces the ARO to 0.1 and the exposure factor to 25% at a cost of $60K per year. What is the net annual benefit?

- A $350K
- B $410K
- C $290K
- D $50K

Q1: Explanation

Correct Answer: C

- Before: ALE = \$2M × 40% × 0.5 = \$400K
- After: ALE = \$2M × 25% × 0.1 = \$50K
- Gross reduction = \$350K
- Net benefit = \$350K − \$60K = \$290K

Critical Trap

\$350K ignores the control cost. \$50K is the residual ALE, not a benefit.

Q2: Joint Probability Bounds

Question

Risk A has a 20% likelihood and Risk B has a 30% likelihood. They are known to be positively correlated. Which statement MUST be true about the probability that both occur?

A. It equals exactly 6%
B. It is at least 50%
C. It can exceed 30%
D. It is strictly greater than 6% and at most 20%

Q2: Explanation

Correct Answer: D

- Independence gives $0.2 \times 0.3 = 6\%$
- Positive correlation pushes the joint probability above 6%
- A joint event can never be more likely than its rarer component
- Upper bound $= \min(20\%, 30\%) = 20\%$

Critical Trap

Correlation changes the joint probability, but it is always capped by the least likely event.

Q3: Annualizing a Monthly Probability

Question

A threat event occurs in any given month with probability 5%, independently of other months. What is the probability of at least one occurrence in 12 months?

- A About 46%
- B About 54%
- C 5%
- D 60%

Q3: Explanation

Correct Answer: A

- $P(\text{none in 12 months}) = 0.95^{12} \approx 0.54$
- $P(\text{at least one}) = 1 - 0.54 \approx 0.46$
- 54% is the probability of NO event
- $12 \times 5\% = 60\%$ ignores overlap of outcomes

Critical Trap

Probabilities of "at least one" do not add linearly. Use the complement.

Q4: Alert Reliability

Question

The probability of a targeted attack this quarter is 10%. When an attack is under way, the detection alert fires 90% of the time. When no attack is under way, it fires falsely 20% of the time. The alert has just fired. What is the probability that an attack is actually under way?

A. 90%
B. 10%
C. About 33%
D. 50%

Q4: Explanation

Correct Answer: C

- $P(\text{alert}) = 0.9 \times 0.1 + 0.2 \times 0.9 = 0.27$
- $P(\text{attack} \mid \text{alert}) = 0.09/0.27 = 1/3$
- A low base rate makes most alerts false positives
- The alert raises the estimate from 10% to 33%, not to 90%

Critical Trap

Detection accuracy is not the same as the probability that an alert is real. Base rates matter.

Q5: Three-Point Estimate

Question

Analysts estimate a loss at $100K (optimistic), $200K (most likely) and $700K (pessimistic). What is the PERT expected loss?

- A $333K
- B $200K
- C $267K
- D $400K

Q5: Explanation

Correct Answer: C

- PERT mean $= (O + 4M + P)/6$
- $= (100 + 800 + 700)/6 \approx \$267K$
- \$333K is the simple average of the three values
- \$200K is the mode and ignores the long tail

Critical Trap

The most likely value is not the expected value when the distribution is skewed.

Q6: Skewed Confidence Interval

Question

A FAIR analysis gives a 90% confidence interval of $200K to $2M with a most likely value of $500K. Which interpretation is BEST?

A. Expected annual loss likely exceeds $500K because of right skew
B. Expected annual loss is exactly $500K
C. The interval is invalid because it is asymmetric
D. The loss will certainly fall inside the interval

Q6: Explanation

Correct Answer: A

- Loss distributions are typically right-skewed (lognormal-like)
- The long upper tail pulls the mean above the mode
- Budgeting on the mode understates expected loss
- A 90% interval leaves a 10% chance of falling outside it

Critical Trap

Most likely $\neq$ expected value. Asymmetric intervals are normal for losses.

Q7: Aggregating Volatility

Question

Two risks each have an annual loss standard deviation of $300K. Their correlation is 0.5. What is the standard deviation of the combined loss?

- (A) $424K
- (B) $300K
- (C) $600K
- (D) $520K

Q7: Explanation

Correct Answer: D

- Var $= \sigma^2 + \sigma^2 + 2\rho\sigma^2 = 3\sigma^2$
- SD $= 300 \times \sqrt{3} \approx \$520K$
- \$424K assumes independence ($\rho = 0$)
- \$600K assumes perfect correlation ($\rho = 1$)

Critical Trap

Standard deviations do not add. Correlation controls how much diversification you get.

Q8: Common-Cause Failure

Question

Two preventive controls each stop an attack 90% of the time. A design review calls them "independent layers," implying a 1% chance that both fail. Testing reveals a shared dependency (the same identity provider) whose failure disables both controls 4% of the time. Otherwise they fail independently. What is the probability that both fail?

A. 1%
B. 4%
C. About 5%
D. 10%

Q8: Explanation

Correct Answer: C

- $P(\text{both fail}) = 0.04 + 0.96 \times 0.10 \times 0.10$
- $= 0.04 + 0.0096 \approx 4.96\%$
- Residual risk is about five times the "independent" estimate
- Defense in depth fails when layers share a failure mode

Critical Trap

Layered controls are only independent if they share no common dependency.

Q9: Rule of Three

Question

A control is tested 30 times with zero failures. Which statement about its true failure rate is MOST defensible?

- A. It is 0%
- B. It is at most 3%
- C. It is at most 30%
- D. It is at most roughly 10% with 95% confidence

Q9: Explanation

Correct Answer: D

- With zero failures in n trials, the 95% upper bound is about $3/n$
- $3/30 = 10\%$
- Zero observed failures does not prove zero failures
- Small samples leave wide uncertainty

Critical Trap

"No failures observed" is not "no failures exist."

Q10: FAIR Decomposition

Question

Threat event frequency is 20 per year and vulnerability (probability a threat event becomes a loss event) is 15%. Primary loss per event is $40K. There is a 30% chance of a secondary loss of $200K per event. What is the annualized loss exposure?

- A $120K
- B $720K
- C $300K
- D $2.0M

Q10: Explanation

Correct Answer: C

- Loss event frequency $= 20 \times 15\% = 3$ per year
- Expected loss per event $= 40K + 0.3 \times 200K = \$100K$
- ALE $= 3 \times \$100K = \$300K$
- \$120K ignores secondary loss; \$720K treats it as certain; \$2.0M ignores vulnerability

Critical Trap

Use loss event frequency, not threat event frequency, and weight secondary loss by its probability.

Q11: Ordinal Matrix Flaw

Question

An organization multiplies 1–5 likelihood and impact scores in a 5x5 matrix. A risk scored 5x1 and a risk scored 1x5 both receive 5. What is the MOST fundamental flaw in this approach?

- A Multiplication always overstates risk
- B Ordinal ranks are not ratio-scale values, so products can misrank risks with very different expected losses
- C A 5x5 matrix is too small
- D Scores above 20 cannot be compared

Q11: Explanation

Correct Answer: B

- Scale points are ordered labels, not measured quantities
- Equal products can hide very different loss profiles
- Products of ordinal ranks can reverse true priority
- Calibrated quantitative ranges are more defensible

Critical Trap

A numeric-looking score does not make an ordinal scale quantitative.

Q12: Aggregate Appetite and Correlation

Question

Three risks each have an expected annual loss of $400K. Aggregate appetite is $1M and aggregate tolerance is $1.3M. The risks are believed to be strongly positively correlated. Which position is MOST accurate?

- **A** Above appetite but within tolerance on an expected basis; correlation does not change the expected sum but fattens the tail, so the loss distribution must be examined
- **B** Within appetite because every individual risk is below $1M
- **C** Beyond tolerance because correlated risks add up to more than their expected values
- **D** Within appetite because diversification lowers the expected aggregate loss

Q12: Explanation

Correct Answer: A

- Expected losses add: $3 \times \$400K = \$1.2M$
- \$1.2M is above appetite (\$1M) and within tolerance (\$1.3M)
- Correlation does not change the expected sum
- Correlation does increase tail (extreme-loss) exposure

Critical Trap

Correlation affects the spread of outcomes, not the sum of expected values.

Q13: Cost Exceeds Benefit

Question

A control costing $400K per year would reduce expected loss by only $150K per year. Without it, residual risk exceeds appetite but is well within capacity. What should the risk practitioner recommend?

- **A** Implement the control because the risk exceeds appetite
- **B** Escalate for formal, documented acceptance by the owner with authority to exceed appetite, while exploring cheaper alternatives
- **C** Accept informally to avoid delay
- **D** Buy full insurance without further analysis

Q13: Explanation

Correct Answer: B

- Treatment must be economically justified
- Exceeding appetite requires explicit authority to accept
- Acceptance must be documented and reviewed
- Cheaper responses should still be explored

Critical Trap

Exceeding appetite does not force a treatment. It forces a decision by the right authority.

Q14: Mitigation That Backfires

Question

After a new control is deployed, the verified residual risk is HIGHER than the original inherent risk. What is the MOST likely explanation?

- **A** An arithmetic error is the only plausible cause
- **B** The control introduced secondary risk that outweighs its benefit, so the response must be redesigned
- **C** Inherent risk was necessarily overstated
- **D** The risk has been transferred to the control owner

Q14: Explanation

Correct Answer: B

- Controls can create new risks (complexity, new attack surface, new dependencies)
- Secondary risk must be assessed alongside residual risk
- Net exposure, not control count, is what matters
- Redesign or replace the response

Critical Trap

A control is not automatically net-positive.

Q15: Recovery Dependencies

Question

System A has an RTO of 4 hours. A's own restoration takes 2 hours and can start only after both System B and System C are available. B takes 3 hours to restore and C takes 2 hours, restored in parallel. Can A meet its RTO?

- **A** Yes, the longest single task is 3 hours
- **B** Yes, B and C run in parallel and fit inside 4 hours
- **C** No, recovery takes 7 hours
- **D** No, recovery takes 5 hours

Q15: Explanation

Correct Answer: D

- B and C run in parallel, so the dependency stage takes $\max(3, 2) = 3$ hours
- A then needs its own 2 hours: $3 + 2 = 5$ hours
- 5 hours exceeds the 4-hour RTO
- 7 hours would be the fully sequential case

Critical Trap

Critical path = longest dependency chain, not the longest single task.

Q16: Probability of Meeting RPO

Question

The RPO is 1 hour and backups run every 4 hours. A failure occurs at a uniformly random time. What is the probability that the data loss stays within the RPO?

- A 0%
- B 25%
- C 50%
- D 75%

Q16: Explanation

Correct Answer: B

- Data loss equals the time since the last backup, uniform from 0 to 4 hours
- Loss is within RPO only when it is at most 1 hour
- Probability $= 1/4 = 25\%$
- Expected loss is 2 hours, twice the RPO

Critical Trap

A backup interval longer than the RPO means the RPO is usually missed.

Q17: MTD Consistency

Question

A process has an RTO of 4 hours, a work recovery time (WRT) of 6 hours and an MTD of 8 hours. What is the PRIMARY problem?

- A Consistent because RTO (4 h) is less than MTD (8 h)
- B Consistent because WRT is excluded from MTD
- C MTD should automatically be raised to 20 hours
- D Inconsistent: RTO plus WRT is 10 hours, which exceeds the 8-hour MTD

Q17: Explanation

Correct Answer: D

- The business must be fully operating again within the MTD
- Requirement: $\text{RTO} + \text{WRT} \leq \text{MTD}$
- Here $4 + 6 = 10 > 8$
- Shorten RTO or WRT, or revalidate the MTD with the business

Critical Trap

Meeting the RTO alone does not guarantee meeting the MTD.

Q18: MTD from Escalating Impact

Question

Outage losses are $10K per hour for the first 4 hours and $50K per hour afterwards. Management defines MTD as the point where cumulative loss reaches $400K. What is the MTD?

- A 11.2 hours
- B 8 hours
- C 4 hours
- D 40 hours

Q18: Explanation

Correct Answer: A

- First 4 hours: $4 \times \$10K = \$40K$
- Remaining threshold: $\$400K - \$40K = \$360K$
- At \$50K per hour: $360/50 = 7.2$ hours
- MTD $= 4 + 7.2 = 11.2$ hours

Critical Trap

Impact is not linear. Piece the loss curve together before dividing.

Q19: Treatment Selection

Question

A risk has an 80% likelihood and a $100K impact. Treatment A costs $50K and cuts likelihood to 20%. Treatment B costs $30K and cuts impact to $40K. Applying both costs $80K. Which option has the best net benefit?

- (A) Both treatments
- (B) Treatment B only
- (C) Neither
- (D) Treatment A only

Q19: Explanation

Correct Answer: B

- Baseline expected loss $= 0.8 \times 100 = \$80K$
- A: loss \$20K, net benefit $= 60 - 50 = +\$10K$
- B: loss \$32K, net benefit $= 48 - 30 = +\$18K$
- Both: loss \$8K, net benefit $= 72 - 80 = -\$8K$

Critical Trap

Benefits of overlapping treatments are not additive. The second one has diminishing value.

Q20: Present Value of a Control

Question

A control costs $120K upfront and reduces expected annual loss from $90K to $20K for 3 years. The discount rate is 10%. What is the approximate NPV?

A. About +$54K, so approve
B. About +$90K
C. About −$50K, so reject
D. About +$210K

Q20: Explanation

Correct Answer: A

- Annual benefit $= \$70K$
- PV factor for 3 years at 10% ≈ 2.487
- PV of benefits $\approx \$174K$
- NPV $\approx 174 - 120 = +\$54K$

Critical Trap

\$90K is the undiscounted net. \$210K is gross undiscounted benefit.

Q21: Insurance Economics

Question

There is a 10% annual chance of a $2M loss. Insurance covers 80% of the loss above a $200K deductible and costs $60K per year. What is the total expected annual cost with insurance?

- A $56K
- B $200K
- C $116K
- D $260K

Q21: Explanation

Correct Answer: C

- Retained per event $= 200K + 20\% \times 1.8M = \$560K$
- Expected retained loss $= 0.1 \times 560K = \$56K$
- Add premium: $56K + 60K = \$116K$
- Uninsured expected loss would be \$200K

Critical Trap

Include the premium and the retained share. Insurance also leaves counterparty and coverage risk.

Q22: Control Test Results

Question

A control runs 250 times per year. A sample of 25 executions shows 5 deviations. The tolerable deviation rate is 5%. What is the BEST conclusion?

- (A) Effective, because the sample is only 10% of the population
- (B) Effective, because 80% of items passed
- (C) Inconclusive until all 250 executions are tested
- (D) Not effective: the 20% sample deviation rate far exceeds the 5% tolerable rate, so remediate and expand testing

Q22: Explanation

Correct Answer: D

- Sample deviation rate $= 5/25 = 20\%$
- 20% is four times the tolerable rate
- A passing rate of 80% is not acceptable here
- Full-population testing is not needed to see a clear failure

Critical Trap

Compare results to the tolerable rate, not to a "mostly passed" feeling.

Q23: Silent Indicators

Question

Every KRI has stayed green for three consecutive years, yet the organization suffered two significant incidents. What is the MOST appropriate conclusion?

- **A** Controls are exceptionally effective
- **B** Thresholds are likely too loose or indicators insensitive, so back-test and recalibrate
- **C** Reduce monitoring frequency to save cost
- **D** Retire the KRIs

Q23: Explanation

Correct Answer: B

- Indicators should have moved before the incidents
- Back-test KRIs against past incidents
- Tighten thresholds and add leading indicators
- Consistent green is a warning sign, not proof of safety

Critical Trap

A KRI that cannot detect a known failure is not doing its job.

Answer Key

Q1: C
Q2: D
Q3: A
Q4: C
Q5: C
Q6: A
Q7: D
Q8: C
Q9: D
Q10: C
Q11: B
Q12: A
Q13: B
Q14: B
Q15: D
Q16: B
Q17: D
Q18: A
Q19: B
Q20: A
Q21: C
Q22: D
Q23: B

Key Takeaways for Domain B

Summary

- **Analysis:** Use complements, base rates, correlation and skew. Do not add intuitively.
- **Evaluation:** Ordinal scores mislead. Aggregate and tail views matter.
- **BIA:** Critical path, RPO versus backup interval, and RTO + WRT $\leq$ MTD.
- **Treatment:** Compare net, discounted benefit. Overlapping controls are not additive.
- **Monitoring:** Compare to tolerable rates. Silent indicators need back-testing.

Good Luck on Your CRISC Exam!

Remember: the ISACA mindset is about
understanding why a question is asked,
not just what is technically correct.